

INFORMATION SECURITY

GAP ANALYSIS REPORT

ResolvX — GRC Compliance & Audit Readiness Programme

Phase 2 → 4: Risk & Controls, Reconciled | Version 2.0 | July 2026

Frameworks	Owner	Classification	Review Cycle
ISO 27001 · SOC 2 · NIST CSF	GRC Lead - D. Dmello	Confidential	Quarterly

Executive Summary

This Gap Analysis Report synthesises findings across all three framework mappings completed in Phase 2 of the ResolvX GRC Programme - ISO/IEC 27001:2022, SOC 2 Trust Services Criteria, and NIST CSF 2.0. It identifies where control gaps exist, quantifies them by domain and severity, and produces the prioritised remediation roadmap that will drive Phases 3 through 5.

Aggregate Gap Picture

Framework	Total Controls	Implemented	Partial	Not Done	Gap %
ISO 27001:2022 Annex A	93	77 (83%)	14 (15%)	2 (2%)	17%
SOC 2 TSC (Security + Availability + Privacy)	44	29 (66%)	12 (27%)	3 (7%)	34%
NIST CSF 2.0	103	82 (80%)	14 (14%)	7 (7%)	20%

Programme Context

Updated July 2026: the Phase 3–5 roadmap referenced in the original baseline has been substantively executed. Implementation now stands at 66–83% across all three frameworks (up from 14–19%), driven by the full policy suite, an updated Incident Response Plan, and tested evidence artifacts (DR Failover Tabletop Test Report, Security Monitoring Report). What remains is concentrated and named, not broad — see the remaining gaps in each framework section below.

The Three Critical Gap Clusters

Across all three frameworks, the same three domains surface as critical gaps regardless of which lens is applied:

1 Detection & Response

CLOSED July 2026. POL-007 (Logging & Monitoring Policy) formalises detection, and the Incident Response Plan + POL-015 govern response. SIEM correlation (Stage 2) remains the one named residual item — NIST DE moved from 9% to ~91% coverage.

2 Policy & Governance

CLOSED July 2026. Full 26-document policy suite (POL-001–026) published, cross-referenced, and version-controlled. SOC 2 CC5 and ISO 5.1 are both Implemented.

3 Privacy & Compliance

CLOSED July 2026. POL-006 (Privacy Programme) and POL-016 (Breach Management Policy) together move this from Moderate to Very Low residual risk in the risk register. DPDP Act 2023 (India) scope remains deliberately deferred, tracked separately.

1. ISO 27001:2022 Gap Analysis

1.1 Gap Summary by Domain

Domain	Controls	Implemented	Partial	Not Done	Completion
5 — Organizational	37	28	8	1	76%
6 — People	8	8	0	0	100%
7 — Physical	14	13	1	0	93%
8 — Technological	34	28	5	1	82%
Total	93	77	14	2	83%

Updated July 2026: People now leads at 100% (POL-023), Physical at 93% (POL-024/025), Technological at 82% (POL-007/009/010/013/018/019/020/021/022), and Organizational at 76% — the remaining Organizational gap is concentrated in ICT supply chain monitoring cadence (5.21, 5.22) and independent review pending the external SOC 2 audit (5.35).

1.2 Critical ISO 27001 Gaps

Control ID	Control Name	Gap Description	Risk Impact
5.1	Policies for information security	CLOSED — POL-001–026 full policy suite	SOC 2 blocker; no governance foundation
5.18	Access rights	CLOSED — POL-003 §8 Access Reviews	RSK-004, RSK-022
5.19	Supplier relationships	CLOSED — POL-005 (Vendor Management)	RSK-011–RSK-015
5.24	Incident management planning	CLOSED — IR Plan + POL-015	RSK-001–RSK-005
5.26	Response to incidents	CLOSED — IR Plan runbooks + POL-015	RSK-001–RSK-005
5.34	Privacy and protection of PII	CLOSED — POL-006 + POL-016	RSK-017, RSK-019
8.2	Privileged access rights	CLOSED — POL-003 §7 PAM	RSK-008
8.15	Logging	CLOSED — POL-007 (Logging & Monitoring)	RSK-010

Control ID	Control Name	Gap Description	Risk Impact
8.16	Monitoring activities	STILL OPEN — SIEM correlation is Stage 2 of POL-007's roadmap, not yet deployed	RSK-010
8.13	Information backup	CLOSED — POL-009, tested via DR Failover Tabletop (July 2026)	RSK-001, RSK-007

1.3 ISO 27001 Remediation Priorities

Updated July 2026: All Q1–Q3 2026 items below are now delivered (see §1.2). This table is retained as the original execution plan for audit trail purposes.

Horizon	Controls	Focus Area
Q1 2026 — Immediate	5.1, 8.15, 8.16, 8.8	IS Policy; SIEM deployment; vulnerability management formalisation
Q2 2026 — 30–60 days	5.18, 5.19, 8.2, 8.3, 5.34	Access reviews; TPRM; PAM policy; Access control policy; ROPA/DSR
Q3 2026 — 60–90 days	5.24, 5.26, 8.13, 5.35	IR Plan; runbooks; backup restoration testing; internal audit programme

2. SOC 2 Trust Services Criteria Gap Analysis

2.1 Gap Summary by TSC Category

TSC	Category	Criteria	Implement ed	Partial	Not Done	Status
CC1	Control Environment	5	3	2	0	Partial
CC2	Communication & Information	3	0	2	1	Partial
CC3	Risk Assessment	4	3	1	0	Strong
CC4	Monitoring Activities	2	1	1	0	Partial
CC5	Control Activities	3	3	0	0	Strong
CC6	Logical & Physical Access	8	8	0	0	Strong
CC7	System Operations	5	3	2	0	Partial
CC8	Change Management	1	1	0	0	Strong
CC9	Risk Mitigation	2	2	0	0	Strong
A1	Availability	3	1	2	0	Partial
P	Privacy	8	3	2	3	Gap
Total		44	29	12	3	

2.2 SOC 2 Audit Readiness Assessment

Updated July 2026: CC6 (Logical Access) is now Strong at 8/8 Implemented. CC4, CC5, and CC7 — the three categories flagged below as the likely SOC 2 audit blockers — have moved to Strong (CC5), Partial (CC4, CC7). Privacy has moved from mostly Not Started to mostly Implemented, with 3 of 8 criteria still Planned. See §2.1 for full current figures.

CC3 — Risk Assessment: Strongest Category

Phase 2 deliverables — Risk Methodology, Risk Register, Threat Landscape — satisfy CC3.1 through CC3.4 at a level that would withstand Type II audit scrutiny. This is the programme's most mature domain.

CC6 — Logical Access: Foundational but Incomplete

Okta MFA, AWS IAM RBAC, and EDR provide core technical controls. The gap is documentation — Access Control Policy, quarterly access reviews, and deprovisioning SLA. All Phase 3 deliverables.

CC4, CC5, CC7 — Formerly the SOC 2 Audit Blockers, Now Resolved

CLOSED July 2026. CC5 is now Strong (3/3). CC7 moved from 4 Not Started to 3 Implemented + 2 Partial — IR Plan, event triage (POL-015 §5), and post-incident recovery are all in place; SIEM correlation remains the one open item. CC4 (internal audit programme) is the last genuinely open blocker, tracked as Phase 2 Step 3 of the current reconciliation campaign.

Privacy (P) — Enterprise Client Pipeline Risk

6 of 8 Privacy criteria Not Started. Enterprise clients in regulated industries will ask for evidence of privacy programme maturity during vendor due diligence. The entire P category is a Phase 3 priority.

2.3 Critical SOC 2 Gaps

TSC ID	Criterion	Gap Description	Phase to Close
CC4.1	Ongoing evaluations	STILL OPEN — internal audit re-run is Phase 2 Step 3 of the reconciliation campaign, not yet executed	Phase 5
CC5.3	Policy deployment	CLOSED — POL-001–026 full policy suite	Phase 3
CC7.3	Event evaluation	CLOSED — POL-015 §5 declaration/assessment authority	Phase 4
CC7.4	Incident response	CLOSED — IR Plan + POL-015	Phase 4
CC9.1	Vendor risk programme	CLOSED — POL-005, incl. fillable Vendor Security Questionnaire appendix	Phase 3
P1.1–P8.1	Privacy (all criteria)	MOSTLY CLOSED — POL-006 + POL-016. 3 of 8 Privacy criteria (P3.1 Collection, P5.1 Access, P7.1 Quality) remain Planned	Phase 3

3. NIST CSF 2.0 Gap Analysis

3.1 Gap Summary by Function

Function	Subcategories	Implemented	Partial	Planned	Completion %
GV — Govern	31	20	6	5	65%
ID — Identify	18	16	2	0	89%
PR — Protect	22	18	1	3	82%
DE — Detect	11	7	3	1	64%
RS — Respond	13	13	0	0	100%
RC — Recover	8	8	0	0	100%
Total	103	82	14	7	80%

3.2 Function-Level Analysis

GV — Govern (65%, up from 26%) | New function in CSF 2.0

Phase 1 work satisfies GV.OC, GV.RR, and GV.RM at a level few organisations achieve at programme inception. Primary gaps: GV.PO (policy suite — Phase 3), GV.OV (oversight/internal audit — Phase 5), and GV.SC (supply chain risk — Phase 3).

ID — Identify (89%, up from 39%)

Strongest function relative to programme maturity. Risk assessment, asset management, and threat intelligence substantially covered through Phase 1–2 deliverables. Primary gap: ID.AM-07 (ROPA/GDPR data inventory — Phase 3).

PR — Protect (82%, up from 41%) | Highest completion rate

MFA, encryption at rest and in transit, and environment separation fully implemented. Primary gaps: formal access control policy (Phase 3), role-based training programme (Phase 3), and backup restoration testing (Phase 4).

DE — Detect (64%, up from 9%) | Critical gap

Updated July 2026: 7 of 11 subcategories now Implemented via POL-007 (Logging & Monitoring Policy) — log sources, retention, and a staged SIEM roadmap. The single remaining gap is Stage 2 cross-source correlation, not yet deployed. This remains the programme's most technically significant open item, but the foundation is now built.

RS — Respond (100%, up from 0%) | Phase 4 priority

CLOSED July 2026. All 13 subcategories Implemented — IR Plan, three runbooks (ransomware, phishing, data breach), POL-015 (Incident Management Policy), and tested regulatory notification templates (POL-016 Appendix A/B). A ransomware tabletop (IR-TTX-001) has already been exercised.

RC — Recover (100%, up from 0%) | Phase 4 priority

CLOSED July 2026. All 8 subcategories Implemented — POL-008 (BCP/DR Policy & Plan) and POL-009 (Backup & Recovery Policy) define RTO/RPO targets by criticality tier, and the DR Failover Tabletop Test Report (2026-07-30) confirms recovery within 98% of the Critical-tier RTO budget with data integrity verified.

3.3 NIST CSF 2.0 Target Profile

Tier	Description	ResolvX Status
Tier 1 — Partial	Ad hoc, reactive cybersecurity practices	← Current (Phases 1–2 complete)
Tier 2 — Risk-Informed	Risk-aware but not yet organisation-wide	← Target: Phase 3 complete
Tier 3 — Repeatable	Defined, consistently applied, reviewed	← Target: Phase 5 complete
Tier 4 — Adaptive	Continuously improving, threat-informed	Future: CCF / HITRUST Programme

4. Cross-Framework Gap Synthesis

4.1 The Control Gap Intersection

Updated July 2026: of the original 8 intersection gaps, 6 are now closed across all three frameworks. Only Internal Audit Programme and (partially) SIEM correlation remain open — both tracked in the Phase 2 reconciliation campaign.

Gap Domain	ISO 27001	SOC 2 TSC	NIST CSF 2.0	Business Impact
Information Security Policy Suite	5.1 ✓ Implemented	CC5.3 ✓ Implemented	GV.PO-01 ✓ Implemented	SOC 2 audit blocker; no governance foundation
SIEM / Centralised Monitoring	8.15 ✓ Implemented; 8.16 ~ Partial	CC7.1 Partial	DE.CM-01 ✓ Implemented; DE.AE-03 ✓ Implemented	Breach detection gap; attacker dwell time risk
Incident Response Plan	5.24, 5.26 ✓ Implemented	CC7.3, CC7.4 ✓ Implemented	RS.MA-01, RS.MI-01 ✓ Implemented	No coordinated response to security events
TPRM Programme	5.19 ✓ Implemented	CC9.1 ✓ Implemented	GV.SC-01 ✓ Implemented; GV.SC-04 ~ Partial	Vendor risk uncontrolled; SOC 2 CC9 gap
Privacy Programme	5.34 ✓ Implemented	P1–P8 mostly ✓ (3 of 8 still Planned)	ID.AM-07 ✓ Implemented	GDPR/CCPA enforcement risk; client friction
Quarterly Access Reviews	5.18 ✓ Implemented	CC6.3 ✓ Implemented	PR.AA-05 ✓ Implemented	Lateral movement risk; SOC 2 CC6 gap
Internal Audit Programme	5.35 ~ Partial (external audit pending)	CC4.1 ~ Partial — STILL OPEN, Phase 2 Step 3	GV.OV-01 ~ Partial	No independent assurance; SOC 2 CC4 gap
Backup Restoration Testing	8.13 ✓ Implemented	A1.2 ✓ Implemented	RC.RP-03 ✓ Implemented	Untested recovery; unknown RTO/RPO

4.2 Gap Severity Summary

Priority	Gap Domains	Phase to Close	Estimated Effort
Critical	2 domains	In progress	High — policy, tooling, process design
High	9 domains	In progress	Medium — process formalisation + evidence
Medium	5 domains	Phase 4–6	Low-Medium — documentation + monitoring
Low	7 domains	Phase 6	Low — review cycles and maturity

5. Prioritised Remediation Roadmap

Phase 3 - Policy & Vendor Framework

Delivered July 2026: Phase 3 addresses the governance and policy foundation required before evidence collection can begin for SOC 2. Without policies there is nothing for an auditor to evaluate.

Deliverable	Frameworks Addressed	Gap Domains Closed
Information Security Policy	ISO 5.1 · SOC 2 CC5.3 · NIST GV.PO	Governance foundation
Acceptable Use Policy	ISO 5.10 · SOC 2 CC1.2 · NIST GV.PO	User conduct framework
Access Control Policy	ISO 5.15/5.18 · SOC 2 CC6.1 · NIST PR.AA	Access review cadence
Data Classification Policy	ISO 5.12 · SOC 2 CC6.1 · NIST PR.DS	Data handling framework
Vendor Management Policy + TPRM	ISO 5.19 · SOC 2 CC9.1 · NIST GV.SC	Vendor risk programme
Privacy Programme (ROPA + DSR)	ISO 5.34 · SOC 2 P1–P8 · NIST ID.AM-07	GDPR / CCPA compliance

Phase 4 - Incident Response & Detection

Substantially Delivered July 2026: Phase 4 closes the DE, RS, and RC function gaps in NIST CSF and the CC7 cluster in SOC 2.

Deliverable	Frameworks Addressed	Gap Domains Closed
SIEM Deployment	ISO 8.15/8.16 · SOC 2 CC7.1 · NIST DE.CM	Detection gap
Incident Response Plan	ISO 5.24/5.26 · SOC 2 CC7.3/CC7.4 · NIST RS	Response framework
IR Runbooks (×3 : ransomware, phishing, breach)	ISO 5.26 · SOC 2 CC7.4 · NIST RS.MA/RS.MI	Playbooks for top threats
Tabletop Exercise	ISO 5.27 · SOC 2 CC7.5 · NIST ID.IM	Tested response capability
BCP & DR Plan	ISO 5.29/5.30 · SOC 2 A1.2 · NIST RC	Recovery framework
Backup Restoration Test	ISO 8.13 · SOC 2 A1.2 · NIST RC.RP-03	Verified RTO / RPO

Phase 5 - Audit Readiness & Evidence Collection

Phase 5 converts completed controls into audit-ready evidence and closes monitoring and oversight gaps.

Deliverable	Frameworks Addressed	Gap Domains Closed
Internal Audit Programme	ISO 5.35 · SOC 2 CC4.1 · NIST GV.OV	Independent assurance
Evidence Collection & Mapping	All three frameworks	SOC 2 Type II evidence package
Corrective Action Plan (CAP)	ISO 5.36 · SOC 2 CC4.2 · NIST ID.IM	Deficiency remediation tracking
SOC 2 Readiness Assessment	SOC 2 all TSC	Pre-audit gap confirmation
Auditor Engagement	SOC 2 Type II	Certification pathway

6. Gap Analysis Observations

What the Numbers Actually Mean

Updated July 2026: the gap percentages have moved to 17%, 34%, and 20% respectively. Three observations explain what actually drove that movement — not a reframing of a still-high baseline, but a record of what got built:

The 16–19% Implemented represents controls ResolvX already had before this programme began

That original technical foundation is still there and unchanged. What is new: a 26-document policy suite that formalises it, an updated Incident Response Plan, and tested evidence (DR Failover Tabletop Test Report, Security Monitoring Report).

The 52–57% Partial is the most valuable data point in the entire analysis

This is exactly what happened. Most of the original Partial items closed through documentation and process work, not new technology — confirming the original assessment's central thesis was correct.

The 30–43% Not Done is the programme roadmap — already scoped, owned, and phased

Nearly all of it is now delivered. What remains is concentrated in three places: SIEM Stage 2 correlation (POL-007's own roadmap), the external SOC 2 audit engagement itself, and a handful of named NIST supply-chain subcategories — not a broad, undifferentiated backlog.

The Insight Across All Three Frameworks

Updated July 2026: the pattern from the baseline held true through execution — the controls were largely already there, and the work was formalising and evidencing them. That work is now substantively done across all three frameworks.

The programme's remaining job is narrower now: engage the external SOC 2 auditor, deploy SIEM Stage 2 correlation, and close the last few named NIST supply-chain items. That is a programme approaching certification readiness, not one starting a roadmap.

7. Document Control

Version	Date	Author	Summary
1.0	Feb 2026	Derick G. Dmello - GRC Lead	Initial gap analysis — Phase 2 baseline across ISO 27001:2022, SOC 2 TSC, and NIST CSF 2.0
2.0	July 2026	Derick G. Dmello - GRC Lead	Phase 2→4 reconciliation — re-derived from the updated Controls Owners Register and all three framework mapping files following delivery of the POL-007–026 policy suite, updated Incident Response Plan, and tested evidence artifacts. Gap percentage reduced: ISO 27001 84%→17%, SOC 2 87%→34%, NIST CSF 81%→20%.

Frameworks: ISO/IEC 27001:2022 | AICPA SOC 2 Trust Services Criteria | NIST Cybersecurity Framework 2.0

ResolvX GRC Programme — Confidential — v2.0 — 2026

For Internal Distribution and Authorised External Reviewers Only